



REST API Specification & Reference

40 RESTful Endpoints, Schemas & Security Invariants

DEVELOPER REFERENCE

Effective Date: September 16, 2026

System: Order Control System v1.0

REST API Specification & Reference

Order Control System — Dark Kitchen Operating Platform

Printable Edition: [Download Executive PDF \(A4 Edition\)](#)

Base URL: `/api` | **Version:** v1.0 | **Protocol:** HTTPS RESTful JSON

Table of Contents

1. [Conventions & Global Security](#)
2. [Authentication](#) (`/api/auth`).
3. [Orders Management](#) (`/api/orders`).
4. [Shifts & Daily Closing](#) (`/api/shifts`, `/api/closing`).
5. [Customer CRM](#) (`/api/customers`).
6. [Delivery & Fleet](#) (`/api/delivery`).
7. [Expenses & Categories](#) (`/api/expenses`).
8. [Menu & Catalog](#) (`/api/menu`).
9. [Reports & Analytics](#) (`/api/reports`).
10. [User Management](#) (`/api/users`).
11. [Audit Trail](#) (`/api/audit`).
12. [Lookups](#) (`/api/lookups`).

1. Conventions & Global Security

Architecture Invariant

Every API endpoint executes `requireRole()` or `requireApiRole()` as its first statement. Requests without valid session credentials return `401 Unauthorized`. Requests from roles with insufficient privileges return `403 Forbidden`.

Standard HTTP Response Codes

Status Code	Description	Scenario
200 OK	Request succeeded	Successful GET, PATCH query
201 Created	Entity created successfully	Successful POST mutation
400 Bad Request	Validation failure	Zod schema validation errors, malformed payload
401 Unauthorized	Unauthenticated	Missing or expired Supabase authentication session
403 Forbidden	Insufficient permissions	Role lacks access (e.g., Cashier attempting discount approval)
404 Not Found	Entity not found	Entity ID does not exist in database
405 Method Not Allowed	Method forbidden	Strict immutability protection (e.g., DELETE on Audit or Customers)

Error Response Schema

```
{
  "code": "VALIDATION_ERROR",
  "message": "Invalid phone number format. Expected 11 digits starting with 01.",
  "errors": []
}
```

2. Authentication (/api/auth)

POST /api/auth/login

Authenticates a user via Supabase Auth and establishes HTTP-only session cookies.

- **Access:** Public
- **Request Body:**

```
{
  "email": "cashier@sushi.local",
  "password": "SecretPassword123!"
}
```

- **Success Response (200):**

```
{
  "user": {
    "id": "uuid-v4",
    "email": "cashier@sushi.local",
    "name": "Mahmoud Hassan",
    "role": "CASHIER",
    "isActive": true
  }
}
```

POST /api/auth/signout

Invalidates the current session and clears cookies.

- **Access:** Authenticated
-

3. Orders Management (/api/orders)

GET /api/orders

Retrieves paginated orders with relational brand, platform, customer, and driver data.

- **Access:** OWNER , MANAGER , CASHIER
- **Query Parameters:**
 - **status** : Filter by OrderStatus (NEW , CONFIRMED , PREPARING , READY , OUT_FOR_DELIVERY , DELIVERED , CANCELLED)
 - **brandId** , **platformId** : UUID filters
 - **date** : YYYY-MM-DD
 - **search** : Searches order numbers, customer names, and phone numbers
 - **page** (default 1), **limit** (default 25, max 100)

POST /api/orders

Creates an order with atomic customer upsert, concurrency-safe advisory lock numbering, and audit logging.

- **Access:** OWNER , MANAGER , CASHIER
- **Request Body:**

```
{
  "platformId": "uuid-platform",
  "brandId": "uuid-brand",
  "externalId": "TAL-994821",
  "customer": {
    "phone": "01099887766",
    "name": "Ahmed Ali",
    "address": "15 Al-Thawra St, Heliopolis"
  },
  "zoneId": "uuid-zone",
  "driverId": "uuid-driver",
  "paymentMethod": "CASH",
  "discount": 0,
  "discountReason": null,
  "notes": "No spicy mayo please",
  "items": [
    { "productId": "uuid-product-1", "quantity": 2 },
    { "productId": "uuid-product-2", "quantity": 1 }
  ]
}
```

- **Success Response (201 Created):** Returns complete created `Order` object with generated `orderNumber` (`ORD-YYYYMMDD-XXXX`).

`GET /api/orders/[id]`

Retrieves full relational details for a single order.

- **Access:** `OWNER` , `MANAGER` , `CASHIER`

`PATCH /api/orders/[id]/status`

Advances order through the deterministic state machine.

- **Access:** `OWNER` , `MANAGER` , `CASHIER`

- **Request Body:**

```
{
  "status": "OUT_FOR_DELIVERY",
  "driverId": "uuid-driver",
  "cancelReason": null
}
```

- **Rules:**
 - Forward-only transitions enforced via `assertTransition()` .
 - Advancing to `OUT_FOR_DELIVERY` requires a valid `driverId` .
 - Transition to `CANCELLED` strictly requires an explicit `cancelReason` .

`POST /api/orders/[id]/discount`

Submits a discount request by cashier.

- **Access:** `OWNER` , `MANAGER` , `CASHIER`

- **Request Body:** { "amount": 50, "reason": "VIP Loyalty Coupon" }

POST /api/orders/[id]/discount/decide

Approves or rejects a pending discount.

- **Access:** OWNER , MANAGER only (Returns 403 for Cashier)
- **Request Body:** { "decision": "APPROVED" | "REJECTED" }

PATCH /api/orders/[id]/driver

Assigns or re-assigns a delivery driver to an order.

- **Access:** OWNER , MANAGER , CASHIER

4. Shifts & Daily Closing (/api/shifts , /api/closing)

GET /api/shifts/current

Returns the active open shift for the requesting cashier/manager.

POST /api/shifts/open

Opens a new operational shift with atomic audit logging. Prevents opening multiple active shifts for the same cashier.

GET /api/shifts/[id]/preview

Computes real-time financial shift preview: total orders, cash/visa/online totals, expenses, and net cash.

POST /api/shifts/[id]/close

Closes active shift and creates the permanent DailyClosing record.

- **Access:** OWNER , MANAGER only (Returns 403 for Cashier)
- **Request Body:** { "notes": "Drawer balanced cleanly" }

GET /api/closing

Returns paginated historical daily closings filtered by date range and cashier.

5. Customer CRM (/api/customers)

GET /api/customers

Retrieves customer directory with RFM metrics, total spend, loyalty tier, and problem order count.

- **Access:** OWNER , MANAGER , CASHIER

GET /api/customers/[id]

Retrieves detailed customer profile including order history, problem orders, favorite sushi items, and notes.

PATCH /api/customers/[id]

Updates customer notes and address with audit logging.

- **Request Body:** { "notes": "Allergic to sesame", "address": "Updated Street 10" }

GET /api/customers/search

High-speed lookup by phone prefix (/api/customers/search?phone=010123).

GET /api/customers/export

Generates and streams a native .xlsx spreadsheet of the customer directory via exceljs with RTL, VIP styling, and @ text phone formatting.

6. Delivery & Fleet (/api/delivery)

- GET /api/delivery/drivers : Lists drivers with active status and driver types (OWN , APP , EXTERNAL , PICKUP).
- POST /api/delivery/drivers : Creates driver profile (OWNER , MANAGER).
- PATCH /api/delivery/drivers/[id] : Updates driver details or soft-deactivates (isActive: false).
- GET /api/delivery/zones : Lists delivery zones with delivery fee amounts.
- POST /api/delivery/zones : Creates new zone (OWNER , MANAGER).
- PATCH /api/delivery/zones/[id] : Updates zone name and delivery fee.

7. Expenses & Categories (/api/expenses)

- GET /api/expenses : Paginated expense logs with date range and expense type filters.
- POST /api/expenses : Records an operational expense tied to active shift.
- PATCH /api/expenses/[id] : Updates expense entry (OWNER , MANAGER).
- DELETE /api/expenses/[id] : Soft deletes expense record (OWNER , MANAGER).
- GET/POST /api/expenses/types : Manages custom operational expense classifications.

8. Menu & Catalog (/api/menu)

- GET /api/menu/brands : Returns active dark kitchen brands (Flower, Mastery, Niwa, Tobiko).
- GET /api/menu/categories : Brand-filtered categories ordered by sortOrder .
- POST /api/menu/categories/reorder : Persists drag-and-drop category display order.
- GET /api/menu/products : Menu items filtered by brand and category.
- POST /api/menu/products : Creates sushi item with name, Arabic title, and price (OWNER , MANAGER).
- PATCH /api/menu/products/[id] : Updates price and details, or deactivates via isActive: false .

9. Reports & Analytics (/api/reports)

GET /api/reports

Executive analytical aggregations over specified date range (startDate , endDate , optional brandId , platformId):

- Sales summaries (Net revenue, total orders, total expenses, net profit, AOV, profit margin).
- Previous period comparison deltas.
- Sales breakdown by Platform × Brand matrix.
- Daily revenue breakdown timeline.
- Driver cash collection reconciliation table.
- Top selling sushi products ranking.

GET /api/reports/employees

Per-cashier performance metrics and discount audit records.

GET /api/reports/peak-hours

24-hour hourly distribution and 7×24 day/hour operational heatmap.

10. User Management (/api/users)

- **Access:** Strictly OWNER only.
- GET /api/users : Lists staff accounts with roles and active status.
- POST /api/users : Provisions new account via Supabase Admin API with generated temporary password.
- PATCH /api/users/[id] : Updates role or toggles active status (isActive: false soft deletion; generates new temporary password on reactivation).

11. Audit Trail (/api/audit)

- **Access:** Strictly OWNER only.
- GET /api/audit : Paginated immutable audit trail with filters (userId , action , entityType , startDate , endDate , search).
- **Strict Immutability Invariant:** Handlers for POST , PUT , PATCH , DELETE return 405 Method Not Allowed .

12. Lookups (/api/lookups)

- GET /api/lookups : Returns cached reference data (brands, platforms, zones, driver types, active categories) in a single request for fast POS client hydration.

Official API Specification for Order Control System. Maintained by Core Engineering.

Order Control System — Multi-Brand Dark Kitchen Operating Platform

Confidential & Proprietary © 2026